Dépendances numériques et résilience organisationnelle : une grille d'analyse du risque cyber en contexte géopolitique

Innocent Twagirumukiza · Octobre 2026

Résumé

Contexte. Le risque cyber est encore largement pensé à partir du périmètre technique que l'organisation administre elle-même. Les rapports institutionnels récents et plusieurs incidents majeurs montrent pourtant que son exposition tient aussi à des ressources qu'elle ne contrôle pas : fournisseurs logiciels, intermédiaires de services, infrastructures, composants matériels, capacités de calcul.

Objectif. L'article cherche à déterminer dans quelles conditions une dépendance externe devient un vecteur de propagation d'un risque cyber, y compris lorsque celui-ci s'inscrit dans un contexte géopolitique, quel rôle y joue la dimension géopolitique, et comment en tenir compte dans la gouvernance du risque cyber.

Méthode. Une analyse conceptuelle propose une typologie de cinq catégories de dépendances et une grille de cinq dimensions (dépendance, concentration, substitution, propagation, résilience). La grille est ensuite appliquée à six situations documentées par des sources publiques : NotPetya et Maersk, SolarWinds, le réseau électrique ukrainien de 2015, Change Healthcare, les terres rares et les dépendances liées à l'intelligence artificielle. Chaque cas reçoit un niveau de preuve quant à sa dimension géopolitique.

Résultats. La distinction entre périmètre technique de sécurité et périmètre de dépendance permet de lire ensemble des événements de nature différente. Dans les cas étudiés, la criticité d'une dépendance paraît liée davantage à la concentration de l'offre, au délai de substitution et à l'absence de mode dégradé qu'à la nature de l'acteur à l'origine de la perturbation. Un lien géopolitique formellement établi n'existe que pour une partie des cas.

Implications. Six orientations sont proposées aux fonctions de gouvernance, de risque et de conformité (GRC), de la cartographie des dépendances réelles au test du fonctionnement dégradé, en passant par la prise en compte de la chaîne d'approvisionnement de l'IA.

Limites. L'étude repose sur des sources documentaires publiques, un nombre restreint de cas et un codage par un seul analyste. Elle n'apporte pas de validation empirique originale.

Mots-clés : cybersécurité ; gestion des risques ; dépendances numériques ; résilience organisationnelle ; géopolitique ; chaîne d'approvisionnement ; gouvernance ; GRC.

1. Introduction

1.1 Contexte et problème

La plupart des cadres de gestion du risque cyber partent de ce que l'organisation administre : postes de travail, serveurs, applications, réseaux, identités, données. La démarche est rationnelle, puisque c'est sur ce périmètre que l'organisation peut agir directement. Elle devient pourtant insuffisante dès que la continuité de l'activité dépend de ressources situées hors de ce périmètre : logiciels édités par des tiers, services d'infrastructure, opérateurs de télécommunications, prestataires de paiement, composants électroniques, énergie.

Le contexte stratégique accentue cette limite. Dans ses conclusions du 16 mars 2026, le Conseil de l'Union européenne souligne que les activités cyber malveillantes constituent souvent une composante essentielle de campagnes hybrides plus larges, menées par des acteurs étatiques ou par des acteurs non étatiques agissant comme intermédiaires d'États (Conseil de l'Union européenne, 2026, point 12). L'ENISA, dans son panorama des menaces de 2026, observe de son côté que les attaques visant les dépendances numériques, y compris les attaques contre la chaîne d'approvisionnement et contre les tiers, entraînent en général des incidents de grande ampleur ou à fort impact (ENISA, 2026a ; ENISA, 2026b). L'administration publique est le secteur le plus ciblé, avec 32 % des cas recensés en 2025 (ENISA, 2026b).

Il en résulte qu'une organisation n'a pas besoin d'être une cible pour être exposée. Une entreprise sans intérêt politique ou militaire particulier appartient malgré tout à un écosystème : elle recourt à un fournisseur d'informatique en nuage, à un opérateur de télécommunications, à des prestataires, à des logiciels développés à l'étranger, à un fournisseur d'énergie, à une banque. Qu'un de ces acteurs soit attaqué, et les effets peuvent lui parvenir sans qu'elle ait jamais été visée. La question habituelle (« suis-je une cible ? ») cède alors la place à une autre : de quoi mon activité dépend-elle, et qui pourrait faire de cette dépendance un levier ?

Ce déplacement pose un problème à la fois de recherche et de pratique. Les travaux sur l'interdépendance et la coercition portent surtout sur les États. Ceux qui traitent des chaînes d'approvisionnement abordent souvent les perturbations de manière générique. Les dispositifs de gestion du risque cyber, enfin, restent centrés sur le périmètre technique. Ces trois corpus se croisent peu, et aucun ne donne à un responsable de la sécurité des systèmes d'information (RSSI) une méthode pour décider quelles dépendances externes méritent une attention particulière quand le contexte géopolitique se dégrade.

1.2 Question de recherche et contribution

La question centrale de l'article est la suivante : dans quelles conditions une dépendance externe devient-elle un vecteur de propagation d'un risque cyber en contexte géopolitique, quel rôle la dimension géopolitique y joue-t-elle, et comment la gouvernance du risque cyber peut-elle en rendre compte ? Trois sous-questions la déclinent. Comment caractériser une dépendance qui compte, par opposition à une simple relation commerciale ? Quels mécanismes de propagation distinguent des événements de nature différente, qu'ils relèvent ou non d'une cyberattaque ? Quelles conséquences en tirer pour les fonctions de gouvernance, de risque et de conformité (GRC) ?

L'article apporte quatre contributions. Il distingue un périmètre technique de sécurité et un périmètre de dépendance. Il propose une typologie de cinq catégories de dépendances et une grille d'analyse de cinq dimensions. Il applique cette grille à six situations documentées, en précisant pour chacune le niveau de preuve du lien géopolitique. Il en déduit six orientations opérationnelles pour la GRC. La démarche est celle d'un article conceptuel : elle procède par synthèse de la littérature puis par confrontation du cadre proposé à des cas (Jaakkola, 2020). Elle ne prétend pas à un test statistique.

1.3 Statut des énoncés et plan

Les énoncés de l'article n'ont pas tous le même statut, et le lecteur doit pouvoir les distinguer. Les faits tirés de rapports institutionnels, de documents officiels ou de comptes rendus d'audit sont présentés comme des constats documentés. Les liens établis entre ces constats et la géopolitique des dépendances relèvent de l'interprétation de l'auteur. Les recommandations de la section 7 sont des propositions de gouvernance, non des conclusions empiriques.

La suite s'organise ainsi. La section 2 situe l'article dans la littérature et le cadre réglementaire. La section 3 présente le cadre conceptuel, y compris une matrice d'intégration de la dimension géopolitique (3.6), et la section 4 la méthode. La section 5 analyse six cas, la section 6 les compare et discute les propositions formulées. La section 7 en tire des implications pour la GRC, la section 8 expose les limites, la section 9 conclut.

2. Cadre théorique et état de l'art

2.1 Interdépendance et coercition

Keohane et Nye (1977) ont montré que l'interdépendance asymétrique est une source de pouvoir : celui qui peut le plus facilement se passer de la relation dispose d'un levier sur l'autre. Farrell et Newman (2019) ont renouvelé ce raisonnement en observant que les réseaux économiques mondiaux (finance, communication, production) ne sont pas répartis de façon homogène mais organisés autour de nœuds centraux. Les États qui exercent une autorité sur ces nœuds peuvent en tirer deux effets : un effet de panoptique, qui donne accès à l'information circulant dans le réseau, et un effet de goulet d'étranglement, qui permet de priver un adversaire de l'accès au réseau. Les plateformes d'informatique en nuage, les systèmes de paiement, les canaux de mise à jour logicielle ou les fabricants de semi-conducteurs avancés présentent précisément ces caractéristiques de nœud central.

Ce cadre fournit donc le mécanisme géopolitique qui manque aux approches centrées sur l'organisation. Il a toutefois une limite pour notre propos : il décrit la stratégie des États, non la position de l'organisation située en aval, qui subit l'exercice d'un levier ou ses effets collatéraux.

2.2 Cyber, conflit et menaces hybrides

Rid (2012) a soutenu que la plupart des opérations cyber relèvent du sabotage, de l'espionnage et de la subversion plutôt que de la guerre au sens strict. Buchanan (2017) a décrit un dilemme de sécurité propre au cyberespace : une intrusion à visée défensive ou de renseignement peut être lue comme la préparation d'une attaque, ce qui nourrit l'escalade. Les documents institutionnels récents prolongent ces analyses. Le Conseil de l'Union européenne rappelle que les menaces hybrides combinent souvent des moyens variés, parmi lesquels la manipulation de l'information et l'ingérence, les cyberattaques, la coercition économique, la coercition diplomatique et les menaces de recours à la force militaire, et qu'elles sont conçues pour rester sous le seuil de ce qui serait perçu comme un acte de guerre (Conseil de l'Union européenne, 2026).

Les objectifs d'une opération ne se limitent donc ni au vol de données ni à la rançon. Il peut s'agir de collecter du renseignement, de préparer une opération future, de déstabiliser un secteur, de perturber un service, de tester une capacité, d'exercer une pression, d'influencer l'opinion ou de produire un effet économique. S'y ajoute une difficulté de lecture : un rançongiciel peut poursuivre un but financier, un déni de service émaner d'hacktivistes, une opération d'espionnage d'un acteur étatique, et ces catégories se recoupent. Pour une organisation, l'attribution est rarement disponible au moment où il faut décider.

2.3 Risque systémique et chaînes d'approvisionnement

Perrow (1984) a montré que les systèmes à la fois complexes et étroitement couplés produisent des accidents que leurs opérateurs ne peuvent ni anticiper ni enrayer à temps. Les chaînes numériques contemporaines présentent ces deux propriétés. La littérature sur les chaînes logistiques en a tiré la notion de vulnérabilité : Christopher et Peck (2004) associent la résilience à la visibilité, à la flexibilité et à la collaboration entre acteurs, tandis que Sheffi (2005) insiste sur le coût caché de la concentration sur un petit nombre de fournisseurs.

Le domaine numérique ajoute une spécificité. La relation de confiance (mise à jour signée, outil de supervision doté de privilèges étendus) devient elle-même une composante du risque. L'ENISA relève d'ailleurs que les dépendances numériques élargissent la surface d'attaque et appellent un niveau de vigilance nouveau (ENISA, 2026b). La boîte à outils de l'UE pour la sécurité de la chaîne d'approvisionnement des TIC, adoptée le 13 février 2026 par le groupe de coopération SRI, propose une approche commune pour identifier, évaluer et atténuer ces risques, y compris ceux qui tiennent à la dépendance envers des fournisseurs à haut risque (Commission européenne / Groupe de coopération SRI, 2026).

2.4 Résilience organisationnelle

En ingénierie de la résilience, celle-ci désigne la capacité d'un système à ajuster son fonctionnement avant, pendant et après une perturbation, de manière à maintenir les opérations requises (Hollnagel et al., 2006). Le NIST décline la cyber-résilience en quatre objectifs : anticiper, résister, récupérer, s'adapter (Ross et al., 2021). La norme ISO 22301 (2019) organise la continuité d'activité autour de l'analyse d'impact et des stratégies de reprise.

Ces référentiels fournissent des instruments solides, mais ils s'adressent d'abord aux systèmes et aux processus que l'organisation maîtrise. La défaillance d'un tiers y figure, le plus souvent, comme un scénario parmi d'autres d'une analyse d'impact, plutôt que comme un objet d'analyse à part entière.

2.5 Cadre réglementaire européen

La directive NIS2 (2022/2555) impose aux entités concernées des mesures de gestion des risques qui couvrent la sécurité de la chaîne d'approvisionnement, y compris les relations avec les fournisseurs directs (art. 21), et prévoit à l'échelle de l'Union des évaluations coordonnées des risques pour les chaînes d'approvisionnement critiques (art. 22). Le règlement DORA (2022/2554) va plus loin pour le secteur financier : il encadre le risque lié aux prestataires de services TIC, exige l'évaluation du risque de concentration et prévoit des stratégies de sortie. Le règlement sur la cyber-résilience (2024/2847) demande aux fabricants une diligence à l'égard des composants tiers intégrés à leurs produits. Le règlement sur l'intelligence artificielle (2024/1689) répartit les obligations entre fournisseurs et déployeurs, ce qui fait de la chaîne de valeur de l'IA un objet de conformité. Les normes ISO/IEC 27001:2022 et ISO/IEC 27036 traitent, pour leur part, des relations avec les fournisseurs.

Ces textes ont un point commun : ils exigent que les risques liés aux tiers soient identifiés et traités. Ils laissent en revanche à l'organisation le soin de définir comment, et la pratique dominante reste le questionnaire de conformité complété d'un registre des prestataires. Le délai de substitution, la tenue du mode dégradé et l'exposition à des décisions politiques n'y figurent pas, ou seulement en partie (DORA), comme des critères explicites.

2.6 Lacune identifiée

Trois discours coexistent donc sans se rejoindre. La théorie de l'interdépendance explique comment les États exploitent les nœuds des réseaux, mais ne descend pas au niveau de l'organisation. La littérature sur les chaînes d'approvisionnement analyse la vulnérabilité des organisations, mais sans mécanisme de coercition géopolitique. Les référentiels de gestion du risque cyber outillent la décision, mais autour d'un périmètre technique. L'article se place à leur intersection : il cherche à traduire, au niveau de l'organisation, ce que l'interdépendance armée fait aux dépendances numériques et matérielles.

3. Cadre conceptuel

3.1 Périmètre technique de sécurité et périmètre de dépendance

L'analyse du risque cyber s'organise le plus souvent autour des actifs que l'organisation administre directement. Nous appelons *périmètre technique de sécurité* l'ensemble des systèmes et des actifs sur lesquels elle peut exercer elle-même des mesures de protection. Nous appelons *périmètre de dépendance* l'ensemble des ressources et des acteurs dont l'indisponibilité ou la compromission peut l'empêcher de remplir ses missions. Les deux périmètres se recouvrent en partie sans coïncider. Un fournisseur d'informatique en nuage peut relever du second sans appartenir au premier, et un poste de travail appartient au premier sans figurer nécessairement dans le second, s'il ne soutient aucune fonction essentielle.

La distinction change la question posée au responsable du risque. Il ne s'agit plus seulement de savoir si ce que l'on administre est protégé, mais de comprendre ce qui permet à l'organisation de fonctionner et ce qui pourrait l'en empêcher. Elle prolonge l'intuition qui fonde l'analyse d'impact sur l'activité, tout en l'appliquant à des ressources que l'organisation ne maîtrise ni sur le plan technique, ni sur le plan juridique, ni parfois sur le plan géographique.

3.2 De la dépendance à la criticité

Une dépendance n'est pas une vulnérabilité. Presque toute organisation dépend de fournisseurs, et cette interconnexion est la condition ordinaire de l'économie numérique. Une dépendance devient un facteur de risque stratégique lorsque plusieurs conditions se cumulent : une forte concentration de l'offre, une difficulté de substitution, un délai de remplacement important, une faible maîtrise de la technologie, une exposition à des décisions politiques ou à des tensions internationales. Les trois premières sont structurelles, la quatrième tient à l'organisation, la dernière au contexte. Nous parlons de *criticité* pour désigner le degré auquel ces conditions sont réunies pour une dépendance donnée.

Cette précision a une conséquence de méthode. La nationalité d'un fournisseur ne suffit pas à mesurer l'exposition géopolitique, qui doit s'appuyer sur des facteurs observables (voir 3.4).

3.3 Typologie des dépendances

Nous distinguons cinq catégories, définies par la nature de la ressource dont dépend l'organisation.

Catégorie	Ressource dont dépend l'organisation	Mode de défaillance typique	Levier géopolitique possible
Logicielle	Logiciels tiers, mises à jour, outils de supervision	Compromission de la chaîne de distribution, perte d'intégrité	Opération étatique contre un éditeur, contraintes juridiques pesant sur lui
Industrielle (OT)	Systèmes de contrôle et équipements techniques connectés	Perte de contrôle, arrêt ou dégradation d'un service physique	Sabotage d'infrastructures essentielles
Intermédiaire de service	Prestataire central d'un secteur (paiement, traitement, infrastructure partagée)	Indisponibilité simultanée d'organisations pourtant indépendantes	Pression sur un nœud central, effet collatéral d'un conflit
Matérielle	Matières premières, composants, capacités de fabrication	Rupture ou restriction d'approvisionnement	Restrictions à l'exportation, sanctions
Algorithmique	Modèles d'IA, calcul, données, services associés	Perte d'accès, altération du modèle, indisponibilité du service	Contrôle des exportations de composants de calcul, juridiction applicable

Les systèmes de régulation frigorifique d'un parc de magasins donnent un exemple de dépendance industrielle à l'état de scénario. Une même technologie déployée sur plusieurs sites crée une dépendance commune, et l'obsolescence, une maintenance insuffisante ou l'absence de solution de secours peuvent produire une défaillance simultanée. Faute d'incident documenté, nous ne retenons pas ce scénario parmi les cas de la section 5. Il illustre seulement la catégorie.

3.4 Grille d'analyse

La grille comprend cinq dimensions. Chacune correspond à une question que le responsable du risque peut poser pour une dépendance donnée.

Dimension	Question	Indicateurs observables	Lecture
Dépendance	Quelles ressources externes sont indispensables à nos activités ?	Cartographie des fonctions essentielles et des ressources qui les soutiennent, contrats, flux	Exposition faible, modérée ou élevée
Concentration	Plusieurs fonctions critiques reposent-elles sur un même fournisseur, une même technologie ou une même zone géographique ?	Part d'un prestataire ou d'une technologie dans les fonctions essentielles, concentration du marché, localisation	Exposition faible, modérée ou élevée

Dimension	Question	Indicateurs observables	Lecture
Substitution	Combien de temps faudrait-il pour remplacer une ressource indisponible ?	Délai estimé de remplacement, coût de migration, existence d'une solution alternative qualifiée	Exposition faible (moins d'une semaine), modérée (une semaine à trois mois), élevée (plus de trois mois)
Propagation	Quelles activités, filiales, infrastructures ou partenaires seraient touchés ?	Nombre de fonctions et d'entités dépendantes, interconnexions	Exposition faible, modérée ou élevée
Résilience	Quelles fonctions peuvent être maintenues en mode dégradé, combien de temps, avec quels moyens ?	Existence et test de procédures dégradées, autonomie en durée, moyens alternatifs	Capacité faible, partielle ou solide

Les quatre premières dimensions mesurent une exposition : plus le niveau est élevé, plus l'organisation est exposée. La cinquième décrit une capacité : plus elle est solide, plus l'exposition est contenue. Les seuils proposés pour la substitution distinguent trois ordres de grandeur : la reprise opérationnelle (jours), la reconfiguration (semaines à quelques mois) et le remplacement structurel (plus de trois mois). Ils sont indicatifs, relèvent d'un choix de l'auteur et devront être calibrés par secteur, par exemple à partir des objectifs de temps de reprise des analyses d'impact.

La dimension géopolitique n'entre pas dans la grille comme un score de plus. Elle est lue à travers des facteurs observables : restrictions commerciales, tensions diplomatiques, concentration industrielle, dépendance à des infrastructures situées à l'étranger, contraintes juridiques, possibilité de sanctions, difficultés d'accès aux services de maintenance. Pour les cas étudiés, elle est consignée à part, sous la forme d'un niveau de preuve défini en 4.4. La section 3.6 propose une matrice pour intégrer cette couche à chaque phase de l'analyse.

3.5 Propositions

Le cadre conduit à trois propositions, que la section 6 confronte aux cas. Elles sont formulées comme des hypothèses de travail : P1 et P3 sont proches de l'intuition et servent surtout à vérifier que la grille ordonne correctement les cas, tandis que P2, qui oppose le caractère étatique de l'acteur à la position structurelle de la dépendance, est la plus discriminante.

P1. La criticité d'une dépendance augmente avec la concentration de l'offre et avec le délai de substitution, quelle que soit la nature, cyber ou non, de l'événement qui la révèle.

P2. La gravité de l'impact sur une organisation dépend moins du caractère étatique de l'acteur à l'origine de la perturbation que de la place qu'occupe la dépendance dans l'architecture des fonctions essentielles, en particulier lorsqu'elle s'accompagne de privilèges étendus ou d'une position centrale dans un secteur.

P3. La capacité de fonctionner en mode dégradé modère la relation entre indisponibilité d'une ressource et perte de fonction : plus elle est solide, plus la durée de la perte est limitée.

3.6 Matrice d'intégration de la dimension géopolitique

La grille de 3.4 mesure une exposition structurelle, et la lecture géopolitique y est tenue à part (3.4, 4.4, 6.5). Pour que cette couche ne reste pas un simple principe, nous proposons une matrice en trois volets qui permet de l'intégrer à chaque phase de l'analyse. Elle prolonge la grille sans la remplacer et ne modifie pas la cotation des cinq dimensions. Son statut est celui d'une proposition de l'auteur : elle n'a pas été validée empiriquement (voir 8.1).

Volet 1 : phases d'analyse et questions géopolitiques. Le premier volet associe à chacune des sept phases de l'analyse (cadrage, cartographie, scénarios, évaluation, traitement, tests, veille) la question géopolitique à poser, les facteurs observables à consulter et le livrable attendu.

Phase	Question géopolitique à poser	Facteurs observables	Livrable
Cadrage	Quelles fonctions essentielles souffriraient si le contexte international se dégradait ?	Secteur, présence à l'étranger, rôle dans des infrastructures critiques	Fonctions essentielles, périmètre de dépendance
Cartographie	De quelles ressources externes dépend-on, et où sont-elles localisées ou juridiquement rattachées ?	Localisation, juridiction, sous-traitants de rang deux, origine des composants	Dépendances classées dans les cinq catégories
Scénarios	Quel levier géopolitique pourrait s'exercer sur chaque dépendance ?	Opération étatique, sanctions, contrôle à l'exportation, pression sur un nœud central	Scénarios cyber et non cyber
Évaluation	Quelle est la cotation sur les cinq dimensions, et quelle est l'activation géopolitique, notée à part ?	Restrictions commerciales, tensions diplomatiques, concentration industrielle, contraintes juridiques, accès à la maintenance	Fiche par dépendance
Traitement	Faut-il réduire, diversifier, surveiller ou compenser la dépendance ?	Délai de substitution, stratégies de sortie, accords de secours	Décision de gouvernance motivée
Tests	Que devient la fonction si la ressource manque 48 heures, une semaine, un mois ?	Procédures dégradées, autonomie en durée	Cote de résilience mise à jour
Veille et revue	Quel signal déclenche une réévaluation de la couche géopolitique ?	Nouvelles restrictions, sanctions, attributions officielles	Déclencheurs de révision

Volet 2 : couche d'activation géopolitique. Le deuxième volet est une fiche par dépendance. Il note trois modulateurs, chacun à trois niveaux (faible, modéré, élevé) : la probabilité de ciblage, la durée probable de la perturbation et l'accès à la maintenance et aux mises à jour. Ces modulateurs reprennent ce que 6.5 attribue à la géopolitique : augmenter la probabilité d'un ciblage, allonger la durée d'une restriction, compliquer l'accès à la maintenance ou aux mises à jour. Chaque cotation est accompagnée d'un niveau de preuve (A à D, défini en 4.4 et à l'annexe A), de la source du signal et d'une date de revue, afin que la couche reste révisable (7.2). Pour une dépendance en cours d'analyse, le niveau de preuve qualifie la source du signal et non un incident passé. Le croisement des catégories de dépendances (3.3) avec leurs leviers possibles guide cette cotation.

Volet 3 : règle de priorisation. L'exposition structurelle (moyenne des quatre premières dimensions, codées de 1 à 3) et l'activation géopolitique (moyenne des trois modulateurs) sont ramenées à trois niveaux : élevé si la moyenne atteint 2,5, modéré à partir de 1,75, faible sinon. Leur croisement donne une priorité de base sur une échelle de cinq crans. La résilience ajuste ensuite cette priorité d'un cran, vers le haut si elle est faible et vers le bas si elle est solide, en cohérence avec P3.

Exposition \ Activation	Faible	Modérée	Élevée
Élevée	Surveiller	Traiter	Traiter en priorité
Modérée	Accepter et suivre	Surveiller	Traiter
Faible	Accepter	Accepter et suivre	Surveiller

Deux garde-fous découlent de l'article. Une activation élevée adossée à un niveau de preuve C (aucun lien établi) est signalée pour vérification, et l'absence de niveau de preuve est signalée dès que l'activation dépasse le niveau faible : on évite ainsi de présumer une dimension géopolitique non démontrée (4.4). Par ailleurs, une exposition structurelle élevée n'est jamais classée au niveau le plus bas, même lorsque l'activation est faible. La matrice ne dit pas que la géopolitique est la cause du risque, mais qu'elle en module la priorité (P2).

Fonctionnement pas à pas.

1. Partir de la cartographie des dépendances (7.1) et classer chacune dans l'une des cinq catégories (3.3).
2. Coter les quatre dimensions d'exposition et la résilience selon la grille (3.4).
3. Coter les trois modulateurs géopolitiques, puis renseigner le niveau de preuve, la source du signal et la date de revue.
4. Lire l'exposition structurelle, l'activation et la priorité finale, et vérifier les alertes de cohérence.
5. Décider (réduire, diversifier, surveiller ou compenser, 7.6) et fixer un déclencheur de révision.

Illustration. Reprenons le distributeur régional de 7.6. La grille donne une dépendance élevée, une concentration élevée, une substitution modérée (une migration prendrait plusieurs semaines), une propagation élevée et une résilience faible : l'exposition structurelle est élevée (moyenne de 2,75). Supposons qu'aucun signal géopolitique ne touche le prestataire d'hébergement et que l'accès à la maintenance dépende de lui : les modulateurs sont faible, faible et modéré, l'activation est faible (moyenne de 1,33) et le niveau de preuve est C. La priorité de base est « surveiller », que la résilience faible relève d'un cran : « traiter ». La décision n'est donc pas de changer de prestataire mais de compenser, en documentant un mode dégradé et en testant une indisponibilité de quarante-huit heures, comme le propose 7.6. Si une tension documentée touchait ensuite l'hébergeur, l'activation monterait et la priorité avec elle.

Outil. Les trois volets sont réunis dans un classeur Excel téléchargeable, avec listes déroulantes, calcul automatique de la priorité, alertes de cohérence et synthèse : Excel (FR) · Excel (EN) · Excel (中文). Les seuils et la matrice de priorité sont des paramètres modifiables, à calibrer par secteur comme les seuils de substitution (3.4).

4. Méthodologie

4.1 Design de la recherche

L'article combine une construction conceptuelle (section 3) et une étude de cas multiples (section 5), qualitative et documentaire. Le choix répond à la nature de la question : il s'agit moins de mesurer la fréquence d'un phénomène que d'éprouver la capacité d'un cadre à rendre intelligibles des événements de nature différente. Les cas servent donc à explorer et à discuter le cadre, non à le tester statistiquement. La généralisation visée est analytique et non statistique, au sens de Yin (2018). La logique d'élaboration théorique à partir de cas suit Eisenhardt (1989).

4.2 Critères de sélection des cas

La sélection est orientée par l'information plutôt que par la représentativité, selon une logique de variation maximale (Flyvbjerg, 2006). Un cas est retenu s'il remplit cinq conditions : l'événement est documenté par au moins une source institutionnelle ou primaire ; il a eu des effets avérés sur la continuité d'activité d'organisations ; il fait jouer un type de dépendance différent des autres cas ; il varie par la nature de l'acteur en cause (étatique, criminel, décision publique) ; il comprend au moins un cas hors du champ strictement cyber, afin de vérifier si le cadre s'étend à d'autres formes de dépendance.

Six situations répondent à ces critères : NotPetya et Maersk (2017), SolarWinds (2020), l'attaque contre le réseau électrique ukrainien (2015), Change Healthcare (2024), les restrictions sur les terres rares (2025) et les dépendances liées à l'intelligence artificielle. Ce dernier cas est prospectif : il ne repose pas sur un incident documenté et il est traité comme tel. Le scénario des systèmes frigorifiques, faute d'incident sourcé, est exclu du corpus.

4.3 Sources

Le corpus mobilise des rapports d'agences publiques et d'institutions européennes, des textes réglementaires, des communications officielles d'attribution, des rapports annuels d'entreprise et des rapports d'audit publics. Les sources primaires sont préférées. La presse spécialisée n'intervient que

pour des éléments factuels absents des autres sources, et elle est alors identifiée comme telle. Chaque affirmation factuelle du texte renvoie à une source de la liste de références.

4.4 Codage

Chaque cas est analysé selon les cinq dimensions de la grille (3.4). Les quatre premières reçoivent un niveau d'exposition (faible, modérée, élevée), la cinquième un niveau de capacité (faible, partielle, solide). Le codage est qualitatif ; il est argumenté dans le texte du cas et justifié dimension par dimension à l'annexe D.

La dimension géopolitique est traitée séparément, par un niveau de preuve en quatre positions. Le niveau A désigne une attribution étatique officielle ou une inculpation documentée. Le niveau B correspond à un contexte géopolitique documenté sans attribution formelle partagée. Le niveau C signale un impact systémique documenté sans lien géopolitique établi. Le niveau D s'applique à une perturbation résultant d'une décision ou d'une politique publique qui n'est pas une opération cyber. Cette séparation évite de présumer une dimension géopolitique là où elle n'est pas démontrée, et de la nier là où elle l'est.

4.5 Validité et biais

La validité de construit repose sur la triangulation des sources et sur la distinction explicite entre faits, interprétations et propositions. Les biais probables sont de trois ordres. La disponibilité de la documentation avantage les incidents de grande ampleur et très commentés. Le regard rétrospectif tend à rendre l'enchaînement des causes plus lisible qu'il ne l'était pour les acteurs. Enfin, le codage a été réalisé par un seul analyste, ce qui limite la fiabilité inter-codeurs. La section 8 revient sur ces limites.

5. Analyse des cas

5.1 NotPetya et Maersk (2017)

L'incident NotPetya de juin 2017 offre un exemple net de propagation du risque au-delà de l'organisation initialement exposée. Le logiciel malveillant s'est diffusé à l'échelle internationale après avoir été introduit dans une chaîne de distribution logicielle utilisée en Ukraine. A. P. Moller-Maersk, groupe de transport maritime et de logistique, a confirmé que ses systèmes avaient été touchés et que ses activités avaient été perturbées. Dans son rapport annuel 2017, l'entreprise estime l'impact de l'attaque entre 250 et 300 millions de dollars, concentré sur Maersk Line (A. P. Moller-Maersk, 2018). Des récits journalistiques détaillés rapportent que la reconstruction du réseau a dépendu en partie d'une copie préservée presque par hasard d'un contrôleur de domaine (Greenberg, 2018).

La dépendance mobilisée est logicielle : la confiance accordée à un canal de mise à jour. L'intérêt du cas tient moins à l'ampleur des dommages informatiques qu'à la manière dont une compromission logicielle a atteint une entreprise dont les opérations reposent sur la coordination de systèmes numériques, d'installations portuaires, de flux de marchandises et de partenaires. La perturbation interne a gagné les opérations physiques, les clients et les partenaires commerciaux : un incident informatique est devenu un problème de continuité économique.

La dimension géopolitique est établie. Les autorités britanniques et américaines ont publiquement attribué NotPetya à l'armée russe le 15 février 2018 (The White House, 2018), et l'inculpation d'officiers du renseignement militaire russe en 2020 y a rattaché l'opération (U.S. Department of Justice, 2020). Le cas relève du niveau A. Il montre qu'une action menée dans un contexte régional peut produire des effets économiques bien au-delà de son théâtre initial.

Lecture par la grille : la dépendance est élevée, la concentration modérée (un logiciel répandu mais local), la substitution modérée (le logiciel comptable est lui-même remplaçable ; c'est la reconstruction du parc informatique, de l'ordre de quelques jours à quelques semaines selon les récits disponibles, qui

a conditionné la reprise), la propagation élevée et la résilience faible, la reprise ayant tenu à des circonstances en partie fortuites. Pour l'organisation, l'enseignement est qu'elle doit être en mesure de contenir les effets d'une attaque qui ne la visait pas nécessairement en priorité.

Maersk n'est pas le seul groupe touché. Chez Maersk, la paralysie des systèmes a affecté la coordination des navires, la gestion des installations portuaires et le suivi des conteneurs (A. P. Moller-Maersk, 2018). Saint-Gobain a estimé l'effet de l'attaque à moins de 250 millions d'euros sur son chiffre d'affaires de l'année, et Merck a indiqué que certaines de ses opérations restaient perturbées (Help Net Security, 2017). Le tableau suivant résume les enseignements du cas.

Dimension	Fait documenté
Géopolitique régionale	Opération attribuée à l'armée russe et dirigée contre l'Ukraine
Vecteur de transmission	Compromission de la mise à jour d'un logiciel comptable local (chaîne d'approvisionnement)
Cybersécurité mondiale	Propagation automatique, au-delà de la cible visée, dans les réseaux d'entreprises multinationales
Conséquence économique	Paralysie d'entreprises étrangères au conflit (Maersk, Saint-Gobain, Merck) et perturbation de chaînes logistiques physiques

NotPetya et Maersk (2017)

NotPetya et Maersk (2017) constitue la preuve parfaite et l'exemple canonique qui illustre comment une cyberattaque conçue pour un conflit géopolitique régional produit des ravages à l'échelle mondiale, sur des cibles qui n'étaient même pas visées à l'origine.

1. L'origine : un conflit géopolitique strictement régional

L'attaque NotPetya s'inscrit initialement dans le contexte géopolitique des tensions militaires et politiques entre la Russie et l'Ukraine :

- **Cible visée à l'origine :** l'écosystème économique ukrainien. Le logiciel malveillant a été introduit via le canal de mise à jour d'un logiciel comptable (M.E.Doc) très utilisé en Ukraine.
- **Attribution étatique :** l'opération a été formellement attribuée à l'armée et au renseignement militaire russes par les autorités britanniques et américaines.

2. Le mécanisme de contagion : la chaîne d'approvisionnement (supply chain)

L'attaque s'est propagée hors des frontières ukrainiennes en exploitant la dépendance logicielle et la confiance accordée aux canaux de mise à jour :

- Il a suffi qu'une entreprise multinationale possède une filiale, un bureau ou simplement un partenariat commercial en Ukraine utilisant ce logiciel pour que l'infection pénètre l'ensemble de son réseau mondial.

3. L'impact mondial : dommages collatéraux hors zone de conflit

Le cas du géant du transport maritime A. P. Moller-Maersk illustre l'effet de débordement mondial (*spillover*) :

- **Infection fortuite :** Maersk n'était pas la cible prioritaire ou stratégique de l'opération militaire russe, mais le malware s'est propagé automatiquement à ses systèmes mondiaux.
- **Passage du cyber au monde physique :** la paralysie des systèmes d'information a directement bloqué les opérations physiques : coordination des navires, gestion des installations portuaires, suivi des conteneurs et flux de marchandises mondiaux.
- **Coût économique massif :** l'impact pour Maersk seul s'est élevé entre 250 et 300 millions de dollars, nécessitant la reconstruction quasi totale de son parc informatique mondial (qui n'a été sauvée que par une copie de sauvegarde conservée par hasard).

Tableau récapitulatif des enseignements de NotPetya

Dimension	Fait démontré
Géopolitique régionale	Cyberattaque étatique conçue pour déstabiliser un pays tiers (l'Ukraine).
Vecteur de transmission	Compromission d'une mise à jour logicielle locale (supply chain).
Cybersécurité mondiale	Propagation automatique non contrôlée à travers le réseau Internet global.
Conséquence économique	Paralysie de géants mondiaux neutres (Maersk, Saint-Gobain, Merck...) et rupture des chaînes logistiques physiques mondiales.

5.2 SolarWinds (2020)

La compromission de la plateforme de supervision Orion de SolarWinds, révélée en décembre 2020, illustre une autre forme de dépendance : celle qui repose sur la confiance accordée aux outils logiciels et à leurs mécanismes de mise à jour. Des versions légitimes du logiciel avaient été altérées pour y intégrer le code malveillant SUNBURST. Les mises à jour distribuées aux clients ont ainsi servi de vecteur d'intrusion. Selon l'éditeur, qui avait notifié environ 33 000 clients d'Orion, moins de 18 000 clients auraient installé une version contenant le code malveillant (SolarWinds Corporation, 2020). Le CERT-FR a documenté l'incident et recommandé aux organisations concernées de vérifier leurs versions, de rechercher des signes de compromission et de tenir compte du risque pesant sur les environnements administrés par la plateforme (CERT-FR, 2020). La CISA américaine a, de son côté, imposé aux agences fédérales la déconnexion des produits Orion concernés (CISA, 2020).

Le problème dépasse la vulnérabilité d'un produit. Un outil de supervision dispose d'une visibilité étendue sur les infrastructures qu'il administre. La confiance qui lui est accordée et les privilèges qui lui sont attribués en font un point d'entrée vers des ressources sensibles. Le cas montre que la conformité d'un fournisseur, la légitimité d'une mise à jour et la réputation d'un éditeur ne suffisent pas à garantir l'intégrité d'une chaîne logicielle : la relation de confiance est elle-même une composante du risque.

Les autorités américaines ont formellement attribué l'opération au service de renseignement extérieur russe (SVR) en avril 2021, en estimant que la compromission de la chaîne logicielle lui donnait la capacité d'espionner ou de perturber plus de 16 000 systèmes informatiques dans le monde (The White House, 2021 ; CISA, 2020) : niveau A.

Lecture par la grille : dépendance élevée, concentration élevée (une plateforme présente chez de très nombreux clients, avec des privilèges étendus), substitution élevée (remplacer un outil de supervision est un chantier de plusieurs mois), propagation élevée, résilience faible, la détection ayant été tardive. La sécurité d'une organisation ne peut pas reposer exclusivement sur la confiance accordée aux composants dont elle dépend.

Comment une crise géopolitique régionale produit des conséquences systémiques

Comment une crise géopolitique localisée dans une région donnée produit des conséquences systémiques sur la cybersécurité mondiale, bien au-delà de la zone de conflit initiale.

La thèse centrale

Dans un monde numérique hyperconnecté, la géopolitique régionale ne reste jamais locale. L'espace cyber ignorant les frontières physiques, une tension géopolitique ciblée sur une région devient instantanément un risque global de cybersécurité pour le reste du monde.

Cette contagion s'opère à travers quatre mécanismes de propagation :

1. L'effet de débordement technique (cyber spillover)

Lorsqu'un État déclenche des cyberattaques destructrices (malwares, essaims de rançongiciels, wiper) contre un pays voisin, le code malveillant se propage de manière incontrôlée sur Internet.

- **Propagation par contamination :** un logiciel malveillant conçu pour paralyser une infrastructure régionale s'infiltre dans les réseaux des multinationales interconnectées à cette région.
- **Impact mondial :** des entreprises situées à des milliers de kilomètres, neutres vis-à-vis du conflit, voient leurs systèmes chiffrés ou détruits simplement parce qu'elles partageaient une ligne de communication ou un serveur localisé dans la zone sous tension.

2. La déstabilisation de la chaîne d'approvisionnement mondiale (supply chain)

Comme illustré par le cas SolarWinds, la plupart des logiciels, composants et services cloud utilisés dans le monde proviennent de chaînes de valeur interconnectées.

- **Attaque du point de confiance :** pour toucher une cible régionale ou un bloc adverse, un attaquant étatique peut compromettre un éditeur de logiciel ou un fabricant de matériel opérant à l'échelle mondiale.
- **Conséquence globale :** en empoisonnant une seule mise à jour logicielle ou en provoquant une pénurie sur un composant physique essentiel (puces, semi-conducteurs), c'est la sécurité et la continuité d'activité de dizaines de milliers d'entreprises mondiales qui sont compromises d'un coup.

3. La mondialisation des cyber-acteurs non étatiques (proxies et hacktivistes)

Les tensions régionales agissent comme un catalyseur pour les groupes de cybercriminels et de mercenaires informatiques.

- **Multiplication des fronts :** des collectifs hacktivistes se mobilisent à travers le globe pour soutenir l'un des belligérants. Leurs cibles ne se limitent pas à la zone de conflit, mais s'étendent aux alliés politiques, économiques et commerciaux des parties opposées.
- **Augmentation du bruit de fond criminel :** l'effondrement de la coopération policière internationale dans une région sous tension crée des zones de non-droit numériques. Les groupes cybercriminels y opèrent en toute impunité, intensifiant leurs attaques par rançongiciels contre le secteur privé mondial.

4. L'onde de choc réglementaire et la rupture de la confiance (splinternet)

La géopolitique régionale oblige les États du monde entier à repenser leur dépendance stratégique vis-à-vis des technologies étrangères.

- **Perte de confiance dans les tiers :** utiliser un logiciel, un composant ou un service cloud conçu dans un pays impliqué dans une crise régionale fait peser un risque immédiat d'espionnage, de porte dérobée (backdoor) ou de rupture de service.
- **Balkanisation du réseau :** en réaction, les gouvernements mondiaux imposent des restrictions d'exportation, des exigences de souveraineté renforcées (ex. directive NIS2) et un cloisonnement des données, morcelant le web global et complexifiant la cybersécurité des entreprises multinationales.

En résumé

Événement géopolitique régional	Mécanisme de transmission	Conséquence sur la cybersécurité mondiale
Conflit armé / cyberattaque ciblée	Propagation incontrôlée du code malveillant	Paralysie collatérale de réseaux d'entreprises neutres à travers le monde.
Pression / sanctions / blocus	Compromission des éditeurs et fournisseurs	Vulnérabilité massive de la chaîne d'approvisionnement logicielle et matérielle mondiale.

Événement géopolitique régional	Mécanisme de transmission	Conséquence sur la cybersécurité mondiale
Tensions diplomatiques	Mobilisation de groupes proxies et hacktivistes	Augmentation globale des attaques par déni de service (DDoS) et fuites de données.
Rupture d'alliances	Durcissement des lois et contrôles à l'export	Obligation de refondre les architectures de sécurité et d'isoler les dépendances technologiques.

5.3 Le réseau électrique ukrainien (2015)

L'attaque de décembre 2015 contre des opérateurs de distribution d'électricité en Ukraine est un cas central pour comprendre les conséquences physiques d'une opération numérique. Les coupures ont touché environ 225 000 clients pendant plusieurs heures, jusqu'à environ six heures selon les analyses. Les attaquants, qui disposaient d'identifiants légitimes, ont pris le contrôle d'interfaces de commande pour provoquer les interruptions, puis ont effacé des systèmes au moyen du logiciel KillDisk, ce qui a compliqué la reprise à distance et obligé les opérateurs à passer en mode manuel (CISA, 2016 ; Lee et al., 2016).

Le cas met en évidence l'interdépendance entre systèmes d'information, technologies opérationnelles et fonctions essentielles d'un territoire. L'indisponibilité d'un système de contrôle ne se traduit pas seulement par une perte de données ou une interruption d'application : elle peut affecter directement la distribution d'une ressource indispensable. Les infrastructures civiles peuvent donc être visées dans un contexte de confrontation et devenir des instruments de pression stratégique.

Le niveau de preuve est A, sur la base de l'inculpation américaine de 2020, qui vise des officiers du renseignement militaire russe pour les attaques contre le réseau électrique ukrainien (U.S. Department of Justice, 2020). L'alerte publiée en 2016 décrit l'attaque et ses mécanismes sans, à notre connaissance, en désigner l'auteur (CISA, 2016) : l'attribution repose donc sur l'inculpation seule.

Lecture par la grille : dépendance élevée, concentration modérée (trois distributeurs aux architectures proches), substitution modérée (le courant a été rétabli en quelques heures grâce à la conduite manuelle, mais la remise en état des systèmes de contrôle numériques a été bien plus longue ; la conduite manuelle relève de la résilience, non de la substitution), propagation modérée, résilience partielle. Ce dernier point mérite d'être souligné : la durée relativement courte des interruptions tient aux procédures manuelles de reprise que les opérateurs avaient conservées. Protéger une infrastructure critique, c'est préserver sa capacité à fournir un service même lorsque ses systèmes numériques sont compromis.

Le réseau électrique ukrainien (2015)

Le cas d'étude sur le réseau électrique ukrainien (2015) franchit un cap supplémentaire : on passe de la dépendance économique ou logicielle à la guerre hybride et à la déstabilisation d'un État.

1. Sur le plan géopolitique : la cyberattaque comme arme de guerre

Contrairement au cas Change Healthcare (cybercriminalité classique sans intention étatique avérée), ce cas illustre l'usage de la cyberattaque comme instrument de pression stratégique et d'agression militaire :

- **Cibler la population et l'économie :** la cyberattaque vise directement les infrastructures civiles (distribution d'électricité) pour semer le chaos, impacter la vie quotidienne de 225 000 citoyens et créer une instabilité politique.
- **L'attribution géopolitique :** la responsabilité est attribuée à un acteur étatique (des officiers du renseignement militaire russe selon l'inculpation américaine de 2020). La cyberdéfense devient alors indissociable de la défense nationale interarmées.
- **La doctrine de la guerre hybride :** une opération numérique est utilisée en parallèle ou en amont de tensions géopolitiques plus larges pour affaiblir un pays cible sans déclencher immédiatement un conflit armé traditionnel.

2. Sur le plan de la cybersécurité : l'impact sur le monde physique (OT / ICS)

Ce cas est emblématique car il montre la convergence entre l'informatique de gestion (IT) et les systèmes industriels / technologies opérationnelles (OT) :

- **Conséquences dans le monde réel :** l'indisponibilité du système numérique ne détruit pas seulement des données, elle prive les usagers d'une ressource vitale physique (l'électricité).
- **Sabotage du système de secours (KillDisk) :** les attaquants ont effacé les systèmes de contrôle pour empêcher la reprise automatique ou à distance, forçant un retour au fonctionnement manuel.
- **La résilience par le « mode dégradé » :** le point fondamental est que la véritable sécurité d'une infrastructure critique repose sur sa capacité à continuer de fonctionner en mode manuel / dégradé lorsque le numérique est compromis.

Tableau comparatif des trois cas d'étude

Cas	Nature du risque	Acteur / intention	Leçon principale
5.6 IA et dépendances de calcul	Risque structurel / dépendance technologique	États (régulation / souveraineté)	Vulnérabilité liée aux chaînes d'approvisionnement mondiales et au matériel.
5.4 Change Healthcare	Risque de concentration / point unique de défaillance	Cybercriminels (lucratif)	Paralysie d'un secteur entier en frappant un seul prestataire central.
5.3 Réseau électrique ukrainien	Sabotage industriel / attaque étatique ciblée	Acteur étatique (géopolitique / militaire)	Nécessité de préserver une capacité de fonctionnement manuel des infrastructures physiques.

5.4 Change Healthcare (2024)

La cyberattaque par rançongiciel subie par Change Healthcare en février 2024 montre les conséquences d'une forte dépendance à un intermédiaire numérique dans un secteur essentiel. Ce prestataire américain intervient notamment dans le traitement des paiements et des opérations administratives liées aux soins de santé. Selon le Government Accountability Office, l'attaque, qui a comporté un vol de données, a entraîné des pertes estimées à 874 millions de dollars et des répercussions étendues sur les prestataires de soins et sur la prise en charge des patients (U.S. GAO, 2024). Ce chiffre n'est qu'un instantané : la maison mère UnitedHealth Group fait état, pour l'exercice 2024, de coûts directs de réponse dépassant les deux milliards de dollars, hors pertes d'activité, et d'un programme de prêts aux prestataires de soins de plus de neuf milliards de dollars (UnitedHealth Group, 2025).

Ce cas révèle un risque de concentration. Lorsqu'un prestataire occupe une position centrale dans le fonctionnement d'un secteur, son indisponibilité peut toucher simultanément des organisations qui restent juridiquement et opérationnellement indépendantes. Chacune peut disposer de son propre dispositif de cybersécurité et se retrouver pourtant face au même point de défaillance.

L'impact systémique doit toutefois être distingué de l'intention stratégique. Il s'agit d'une attaque par rançongiciel, et aucun élément public ne la relie, à notre connaissance, à une stratégie étatique (U.S. GAO, 2024). Elle démontre les conséquences d'une dépendance centralisée, mais elle ne suffit pas à établir une opération de déstabilisation étatique : niveau C.

Lecture par la grille : dépendance élevée, concentration élevée, substitution élevée, propagation élevée, résilience faible. Le cas est précieux pour la proposition P2 : il produit un impact sectoriel considérable sans acteur étatique avéré.

Change Healthcare (2024)

Change Healthcare (2024) illustre parfaitement ce qu'on appelle en cybersécurité un risque de concentration et un point unique de défaillance (*single point of failure*), deux notions qui ont de lourdes conséquences aussi bien en cybersécurité qu'en géopolitique.

1. Du point de vue de la cybersécurité : le piège de la concentration

Le cas montre un phénomène très répandu : même si chaque hôpital ou pharmacie gère bien sa propre sécurité informatique, tous dépendent du même intermédiaire central pour traiter leurs opérations et paiements.

- **Effet domino (propagation) :** en frappant une seule cible (l'intermédiaire), les cybercriminels ont paralysé tout un secteur d'activité (santé, paiements, soins aux patients).
- **L'illusion de l'autonomie :** une organisation peut investir massivement dans sa propre sécurité, mais rester totalement vulnérable si le prestataire externe auquel elle est reliée s'effondre.
- **Coûts disproportionnés :** l'impact financier dépasse de loin le coût de l'attaque initiale (des milliards de dollars de pertes indirectes et de soutien financier d'urgence).

2. Du point de vue géopolitique : une vulnérabilité stratégique exploitable

Même si l'attaque de 2024 contre Change Healthcare était une cybercriminalité classique à but lucratif (rançongiciel) et non une attaque étatique, ce cas de figure révèle une faiblesse majeure qu'un État rival pourrait exploiter en temps de crise :

- **Mise en évidence des « goulots d'étranglement » (chokepoints) :** les adversaires étatiques étudient ces dépendances économiques et techniques. En cas de tensions géopolitiques ou de conflit (guerre hybride), attaquer un ou deux acteurs clés d'un pays ennemi permet de déstabiliser toute sa société sans avoir à cibler chaque entité individuellement.
- **Souveraineté et dépendance envers des acteurs étrangers :** si une nation dépend entièrement de prestataires numériques concentrés (qu'ils soient sur son sol ou dans un pays tiers), sa sécurité nationale est conditionnée par la résilience de ces quelques entreprises privées.
- **Armement de la chaîne d'approvisionnement :** ce type de dépendance montre qu'un acteur hostile n'a pas besoin de détruire une infrastructure critique physique (réseau électrique, barrages) pour semer le chaos ; bloquer les flux de données ou financiers d'un intermédiaire monopolistique suffit.

En résumé

La concentration des services numériques transforme la vulnérabilité d'un seul acteur privé en un risque systémique pour toute une nation. C'est à la fois une faille majeure de cybersécurité et un levier de pression géopolitique redoutable en cas de conflit.

5.5 Les terres rares (2025)

La géopolitique des dépendances ne se limite pas aux logiciels et aux réseaux. Elle concerne aussi les matériaux et les composants nécessaires à la fabrication des technologies contemporaines. Selon l'Agence internationale de l'énergie, la Chine représentait en 2024 environ 60 % de la production minière mondiale des terres rares utilisées dans les aimants, 91 % de leur production raffinée et 94 % de la fabrication mondiale des aimants permanents frittés concernés (IEA, 2025). La dépendance stratégique ne résulte donc pas seulement de la disponibilité géologique, mais aussi de la concentration des capacités industrielles de transformation.

Les contrôles à l'exportation introduits par la Chine le 4 avril 2025 sur sept terres rares lourdes, leurs composés et les aimants correspondants ont montré les conséquences possibles de cette concentration. L'AIE indique que des constructeurs automobiles en Europe, aux États-Unis et ailleurs ont rencontré

des difficultés d'approvisionnement, certains réduisant leur taux d'utilisation ou suspendant temporairement des usines. Des contrôles plus larges, annoncés le 9 octobre 2025, visent désormais aussi les pièces, composants et assemblages contenant des terres rares d'origine chinoise (IEA, 2025).

Ce cas n'est pas une cyberattaque. Il élargit pourtant l'analyse : une organisation peut disposer d'une infrastructure numérique correctement sécurisée et rester vulnérable à une décision extérieure qui coupe l'accès à un composant indispensable. Le niveau de preuve est D, puisque la perturbation résulte d'une décision publique.

Lecture par la grille : dépendance élevée, concentration élevée, substitution élevée, propagation élevée, résilience partielle, les entreprises concernées ayant pu, pour certaines, ajuster leur production sans l'interrompre complètement.

Pour les organisations, les conséquences possibles de cette situation sont les suivantes. Il s'agit d'une lecture de l'auteur, qui reste à tester et que le cas n'établit pas : allongement de la durée de vie du matériel, avec davantage de vulnérabilités non corrigées ; recours à des achats de dépannage moins sûrs, avec le risque de composants contrefaits ou mal qualifiés ; pression budgétaire au détriment de la sécurité ; fragilité de la couche physique du numérique, notamment les pièces de rechange des centres de données et des systèmes industriels.

Les terres rares (2025)

Une organisation peut avoir une infrastructure numérique bien sécurisée et rester vulnérable à une décision extérieure qui coupe l'accès à un composant indispensable. La cybersécurité ne protège alors que ce que l'organisation administre, alors que la disponibilité du matériel dépend de ressources hors de son périmètre. C'est la distinction entre périmètre technique et périmètre de dépendance (3.1).

Conséquences possibles (raisonnement de l'auteur)

1. Allongement de la durée de vie du matériel, donc plus de vulnérabilités. Si le renouvellement des équipements est retardé ou plus cher, les organisations gardent plus longtemps des équipements anciens, parfois sans correctifs de sécurité. C'est un risque classique des environnements industriels (OT).

2. Achats de dépannage moins sûrs. Face à une pénurie, on se tourne vers de nouveaux fournisseurs, des courtiers ou le marché gris. Les risques de composants contrefaits, altérés ou mal qualifiés augmentent, et la vérification de l'intégrité de la chaîne d'approvisionnement passe au second plan.

3. Pression sur les budgets. Si le matériel devient plus cher, le budget peut être réorienté vers la continuité d'approvisionnement au détriment de la sécurité.

4. Fragilité de la couche physique du numérique. Certains composants électromécaniques (moteurs, ventilateurs, alimentations, stockage) peuvent dépendre de ces matériaux selon les cas. Une pénurie peut affecter les pièces de rechange des centres de données et des systèmes industriels, donc la capacité à maintenir un service ou à le restaurer après un incident.

5. Contexte de tension plus large. L'article note que les menaces hybrides combinent coercition économique et cyber (2.2). Une restriction à l'exportation peut accompagner une hausse des opérations étatiques, ce qui augmente la probabilité de ciblage (le premier modulateur de la matrice 3.6).

Lecture avec la grille et la matrice

- Catégorie matérielle, niveau de preuve D (décision publique, pas d'attribution cyber).
- Dépendance, concentration, substitution et propagation élevées, résilience partielle.
- Dans la matrice, c'est le cas où l'exposition structurelle est forte alors que l'activation géopolitique reste à documenter. La priorité vient donc surtout de la structure de la dépendance (la proposition P2), pas de l'identité d'un attaquant.

Réponses concrètes pour un RSSI

- Cartographier les équipements critiques dont la chaîne d'approvisionnement passe par ces composants.
- Constituer des stocks de pièces de rechange pour les fonctions essentielles.
- Prévoir des mesures compensatoires (segmentation, surveillance renforcée) pour le matériel obsolète conservé.
- Qualifier à l'avance des fournisseurs alternatifs, avant la crise.
- Tester le fonctionnement en mode dégradé (7.3).

5.6 L'intelligence artificielle et les dépendances de calcul (cas prospectif)

Le développement de systèmes d'IA avancés repose sur des ressources interdépendantes : semi-conducteurs spécialisés, infrastructures de calcul, centres de données, énergie, données d'entraînement, modèles, compétences scientifiques et services d'informatique en nuage. Leur maîtrise est inégalement répartie entre États et acteurs industriels. Une organisation peut posséder ses données et définir ses politiques de sécurité tout en dépendant d'un fournisseur extérieur pour accéder à un modèle, exécuter des traitements ou maintenir un service essentiel.

L'IA transforme aussi le paysage des menaces. L'ENISA observe un recours croissant à l'IA par des groupes malveillants, principalement pour faciliter ou amplifier leurs activités, et note que l'intégration de systèmes d'IA dans les environnements professionnels élargit la surface d'attaque : ces systèmes sont à la fois des outils et des cibles (ENISA, 2025 ; ENISA, 2026b). Le NIST a par ailleurs formalisé les catégories d'attaques contre les systèmes d'apprentissage automatique : évasion, empoisonnement et atteintes à la confidentialité pour l'IA prédictive, auxquelles s'ajoutent, pour l'IA générative, les attaques sur la chaîne d'approvisionnement, l'injection d'instructions et les détournements d'usage (Vassilev et al., 2025). Les restrictions à l'exportation de technologies de calcul avancé montrent enfin que les composants nécessaires à l'IA sont devenus des instruments de politique de sécurité nationale. Le cadre dit de diffusion de l'IA, publié en janvier 2025 (U.S. Department of Commerce / BIS, 2025), a toutefois fait l'objet d'une annonce d'abrogation par le BIS en mai 2025, avant son entrée en application, et son remplacement n'était toujours pas publié à la mi-2026, les contrôles antérieurs sur les puces avancées demeurant en vigueur (Miller & Chevalier, 2026). Cette instabilité illustre elle-même le caractère mouvant de ces leviers.

Ce cas diffère des précédents : il ne s'appuie pas sur un incident documenté de perturbation massive. Il est retenu parce que la structure de dépendance y est visible avant toute crise, ce qui permet d'éprouver la grille de manière préventive. La question devient : de quoi dépend notre IA ? Modèle, nuage, données, interfaces de programmation, infrastructure, éditeur, processeurs graphiques, chaîne logicielle. Une indisponibilité de quarante-huit heures d'un fournisseur de modèle serait-elle supportable pour les fonctions qui s'appuient sur lui ?

Lecture par la grille : le codage est indicatif : dépendance modérée à élevée selon les organisations, concentration élevée, substitution élevée, propagation modérée, résilience à documenter. Le niveau de preuve est D, pour la couche de calcul.

Le tableau suivant propose une lecture des positions des grands blocs. C'est une hypothèse de travail de l'auteur, appuyée sur les sources citées ci-dessus, et non un résultat empirique.

Bloc	Position géopolitique	Priorité en cybersécurité
États-Unis	Dominant, protecteur	Protéger la propriété intellectuelle et contrôler la diffusion des technologies de calcul avancé
Chine	Challenger en quête d'autonomie	Développer des alternatives souveraines et réduire la dépendance aux puces avancées soumises à restrictions
Europe	Dépendante, régulatrice	Gérer le risque de rupture de service et sécuriser les usages (AI Act, NIS2, RGPD)

Le lien entre géopolitique et cybersécurité de l'IA

1. Le point de vue des États-Unis : garder l'avance et fermer le jeu

Les États-Unis sont aujourd'hui en position de force sur la majorité de la chaîne (conception des puces comme Nvidia, géants du cloud comme AWS / Microsoft / Google, et modèles majeurs).

- **Enjeu géopolitique :** maintenir leur suprématie technologique et empêcher leurs rivaux (principalement la Chine) d'accéder aux technologies de calcul de pointe. Cela se traduit par des régulations et des contrôles à l'exportation stricts sur les puces et les équipements.
- **Impact cybersécurité :**
  - **Protection du secret industriel :** risque élevé d'espionnage économique et de cyberattaques étatiques visant à voler leur propriété intellectuelle (puces, architecture de modèles).
  - **Sécurisation de la chaîne d'approvisionnement :** volonté de rapatrier la fabrication (via le Chips Act) pour éviter de dépendre d'usines vulnérables en Asie (notamment à Taïwan).

2. Le point de vue de la Chine : atteindre l'autonomie et contourner les blocus

La Chine fait face à des restrictions d'accès aux processeurs les plus puissants sous l'impulsion américaine.

- **Enjeu géopolitique :** viser l'autonomie stratégique complète en développant ses propres puces, infrastructures de calcul et modèles d'IA souverains pour ne plus dépendre des technologies américaines.
- **Impact cybersécurité :**
  - **Contournement et renseignement :** recours accru à la recherche souveraine, mais aussi au cyberespionnage pour combler le retard technologique.
  - **Risques de failles sur le matériel alternatif :** l'utilisation de puces ou de logiciels développés en urgence pour remplacer les standards américains peut introduire de nouvelles vulnérabilités ou failles de sécurité non détectées.

3. Le point de vue de l'Europe : subir la dépendance et tenter de réguler

L'Europe dispose de talents et de laboratoires de recherche, mais dépend très fortement des puces américaines et asiatiques et du cloud américain pour exécuter l'IA à grande échelle.

- **Enjeu géopolitique :** trouver une voie de souveraineté numérique pour éviter de devenir un simple « terrain de jeu » ou un client captif des géants américains et chinois.
- **Impact cybersécurité :**
  - **Risque de rupture ou de pression politique :** si un fournisseur américain coupe l'accès à ses serveurs ou modèles pendant 48 heures (ou en cas de conflit réglementaire / sanction), les entreprises européennes se retrouvent paralysées.
  - **Stratégie par la conformité et la sécurité :** mise en place de réglementations strictes (AI Act, NIS2, RGPD) et d'évaluations de risques (comme les travaux de l'ENISA cités plus haut) pour forcer les éditeurs à sécuriser leurs chaînes d'approvisionnement et à garantir la résilience des systèmes.

En résumé

Bloc	Position géopolitique	Priorité en cybersécurité
États-Unis	Dominant / protecteur	Protéger la propriété intellectuelle et contrôler la diffusion
Chine	Challenger / en quête d'autonomie	Développer des alternatives souveraines et contourner les blocus

Bloc	Position géopolitique	Priorité en cybersécurité
Europe	Dépendant / régulateur	Gérer le risque de rupture de service et sécuriser les usages

5.7 Mécanismes de propagation : lecture transversale

Les six cas permettent une lecture transversale des voies par lesquelles un événement géopolitique régional peut devenir un risque pour des organisations éloignées de son théâtre. Cette lecture est une analyse de l'auteur. Deux des quatre mécanismes ci-dessous sont observés dans les cas, les deux autres sont des hypothèses à éprouver. Proposer de telles hypothèses relève du rôle d'un cadre conceptuel : elles ne constituent pas des résultats.

- **Débordement technique (cyber spillover).** Un code malveillant conçu pour un théâtre régional se propage de façon non maîtrisée. Mécanisme observé : NotPetya (5.1).
- **Fragilisation de la chaîne d'approvisionnement mondiale.** Des éditeurs ou des fournisseurs à portée mondiale sont compromis, ou l'accès à des composants est restreint. Mécanisme observé : SolarWinds (5.2) et terres rares (5.5).
- **Mobilisation d'acteurs non étatiques.** Des groupes hacktivistes ou criminels amplifient un front de conflit. Hypothèse : Change Healthcare (5.4) montre l'impact sectoriel d'un groupe criminel, mais aucun cas du corpus ne documente une mobilisation de ce type liée à un conflit.
- **Fragmentation des réseaux et rupture de confiance réglementaire.** Les contrôles à l'exportation et les exigences de souveraineté se durcissent, au point de fragmenter les environnements technologiques. Hypothèse, illustrée en partie par les contrôles sur les terres rares (5.5) et l'instabilité du cadre applicable aux puces d'IA (5.6) ; la fragmentation d'Internet elle-même n'est pas observée dans le corpus.

Le tableau suivant met ces mécanismes en regard de l'événement qui les déclenche et de leur conséquence possible pour la cybersécurité d'organisations éloignées.

Événement géopolitique régional	Mécanisme de transmission	Conséquence possible pour des organisations éloignées	Statut
Conflit armé, cyberattaque ciblée	Propagation incontrôlée du code malveillant	Paralysie collatérale de réseaux d'entreprises étrangères au conflit	Observé (NotPetya)
Pression, sanctions, blocus	Compromission d'éditeurs et de fournisseurs ; restriction d'accès aux composants	Vulnérabilité de la chaîne d'approvisionnement logicielle et matérielle	Observé (SolarWinds, terres rares)
Tensions diplomatiques	Mobilisation de groupes proxies et hacktivistes	Hausse possible des attaques par déni de service et des fuites de données	Hypothèse de l'auteur
Rupture d'alliances	Durcissement des lois et des contrôles à l'exportation	Refonte des architectures de sécurité et isolement de dépendances technologiques	Hypothèse de l'auteur, illustrée en partie (5.5, 5.6)

Source : analyse de l'auteur, à partir des cas 5.1 à 5.6. Les lignes 3 et 4 restent à éprouver sur d'autres cas, par exemple des campagnes de déni de service liées à un conflit ou des épisodes de fragmentation réglementaire. Elles figurent ici pour ouvrir la discussion, ce qui prolonge les limites exposées en section 8.

6. Synthèse et discussion

6.1 Synthèse comparative

Le tableau suivant reprend le codage de chaque cas. Les quatre premières dimensions expriment une exposition, la cinquième une capacité, la dernière colonne le niveau de preuve géopolitique défini en 4.4. Le codage est celui de l'auteur, justifié à l'annexe D, et reste argumentable.

Cas	Catégorie	Dépendance	Concentration	Substitution	Propagation	Résilience	Preuve géopol.
NotPetya / Maersk (2017)	Logicielle	Élevée	Modérée	Modérée	Élevée	Faible	A
SolarWinds (2020)	Logicielle	Élevée	Élevée	Élevée	Élevée	Faible	A
Réseau ukrainien (2015)	Industrielle (OT)	Élevée	Modérée	Modérée	Modérée	Partielle	A
Change Healthcare (2024)	Intermédiaire de service	Élevée	Élevée	Élevée	Élevée	Faible	C
Terres rares (2025)	Matérielle	Élevée	Élevée	Élevée	Élevée	Partielle	D
IA et calcul (prospectif)	Algorithmique	Modérée à élevée	Élevée	Élevée	Modérée	À documenter	D

6.2 Résultats transversaux

Trois constats se dégagent. Le premier est qu'une dépendance devient particulièrement sensible lorsqu'elle est difficile à remplacer et qu'elle conditionne une fonction essentielle. Les cas où la concentration et la difficulté de substitution sont toutes deux élevées (SolarWinds, Change Healthcare, terres rares) sont aussi ceux où l'effet se déploie sur un secteur ou un ensemble d'organisations plutôt que sur une seule.

Le deuxième est que l'interconnexion amplifie les conséquences d'un incident au-delà de son point d'origine. NotPetya touche une entreprise de logistique à partir d'un logiciel fiscal ukrainien, et Change Healthcare atteint des acteurs de santé qui n'ont aucun lien entre eux, sinon le même intermédiaire.

Le troisième est que les vulnérabilités peuvent naître aussi bien d'une attaque informatique que d'une concentration industrielle ou d'une décision commerciale ou politique. Mettre sur le même plan un rançongiciel et une restriction d'exportation n'a de sens que si l'on garde en tête leurs statuts différents, ce que le niveau de preuve géopolitique rend explicite.

6.3 Retour sur les propositions

Le codage ayant été réalisé par l'auteur à l'aide de la grille elle-même, la concordance relevée ci-dessous vérifie la cohérence interne du cadre plus qu'elle ne le valide : P1 et P3 sont proches de l'intuition, et P2 est la proposition la plus discriminante.

P1 est cohérente avec les cas. Les situations de concentration et de substitution élevées (SolarWinds, Change Healthcare, terres rares) sont celles dont la portée est la plus large, alors que le cas ukrainien, où concentration, substitution et propagation sont modérées, reste circonscrit à trois distributeurs. La proposition tient au-delà de la frontière entre événements cyber et non cyber, puisque le cas des terres rares la confirme sans aucune cyberattaque.

P2 est cohérente avec les cas. Change Healthcare produit un impact sectoriel considérable sans acteur étatique avéré, alors que l'attaque ukrainienne, imputée à un acteur étatique, a eu une durée limitée. Ce qui différencie les situations tient davantage à la place de la dépendance dans l'architecture des fonctions et à ses privilèges (SolarWinds) qu'à l'identité de l'attaquant. La nature de l'acteur modifie toutefois d'autres paramètres, comme la probabilité d'un ciblage délibéré ou la durée d'une restriction, que le présent corpus ne permet pas d'apprécier.

P3 est également soutenue. Le cas ukrainien, où les opérateurs ont gardé des procédures manuelles, présente des interruptions de quelques heures ; Maersk, dont la reprise a tenu à des circonstances en partie fortuites, subit une perturbation plus profonde. Dans le cas des terres rares, certains constructeurs ont pu réduire leur production plutôt que l'arrêter. Ces rapprochements restent des indices. Ils ne constituent pas un test, et d'autres facteurs interviennent dans chaque cas.

6.4 Apport par rapport aux dispositifs existants

La grille ne prétend pas inventer ses notions : concentration, délai de substitution et stratégies de sortie existent déjà, séparément, dans l'ISO 22301, dans DORA et dans la littérature sur les chaînes d'approvisionnement. Sa contribution est de les articuler dans une même grille, applicable à des dépendances de natures différentes. Elle ne remplace ni l'analyse d'impact de l'ISO 22301, ni les exigences fournisseurs de NIS2 et de DORA. Elle les complète sur trois points. Elle fait du délai de substitution et du mode dégradé des critères explicites et comparables, là où les textes exigent seulement que les risques soient traités. Elle traite la dépendance matérielle et la dépendance algorithmique dans le même cadre que la dépendance numérique. Elle propose enfin de lire l'exposition géopolitique à partir de facteurs observables plutôt qu'à partir de la nationalité des fournisseurs.

6.5 Ce que la géopolitique ajoute, et ce qu'elle n'explique pas

Un lien géopolitique formellement établi n'existe que pour trois des cinq cas observés (niveau A), le sixième étant prospectif. Dans les autres, la dimension géopolitique est soit absente (niveau C), soit indirecte (niveau D). Ce constat invite à la prudence : le cadre ne démontre pas que toute dépendance critique est un instrument géopolitique. Il montre qu'une dépendance critique est un vecteur de propagation quelle que soit l'origine de la perturbation, et que la géopolitique agit surtout comme un modulateur : elle augmente la probabilité d'un ciblage, elle peut allonger la durée d'une restriction, elle peut compliquer l'accès à la maintenance ou aux mises à jour. C'est pourquoi la lecture géopolitique doit rester une couche d'analyse ajoutée à la grille, et non un critère qui la remplace.

7. Implications pour la GRC

Les propositions qui suivent sont des recommandations de gouvernance formulées par l'auteur à partir de l'analyse précédente. Elles ne constituent pas des conclusions empiriques.

7.1 Cartographier les dépendances réelles

Le questionnaire annuel de conformité reste utile, mais il décrit ce que le fournisseur déclare, non ce dont l'organisation dépend. La première étape consiste à partir des fonctions essentielles et à remonter vers les ressources qui les soutiennent, y compris les sous-traitants de rang deux et les composants matériels. Cette cartographie alimente directement les dimensions de dépendance, de concentration et de propagation de la grille.

7.2 Intégrer la dimension géopolitique dans l'analyse des fournisseurs

La géopolitique ne doit pas se réduire à un indicateur fondé sur la nationalité du fournisseur. Elle gagne à s'appuyer sur des facteurs observables : restrictions commerciales, tensions diplomatiques, concentration industrielle, dépendance à des infrastructures situées à l'étranger, contraintes juridiques, possibilités de sanctions, difficultés d'accès à la maintenance. Ces facteurs se consignent comme une couche d'analyse distincte, révisable quand le contexte évolue. La matrice de la section 3.6 propose une manière de consigner cette couche et de la relier à la priorisation des dépendances.

7.3 Tester le fonctionnement en mode dégradé

Aucune organisation ne peut raisonnablement postuler qu'elle empêchera toutes les attaques. Il faut donc savoir combien de temps elle peut fonctionner si un fournisseur critique devient indisponible. Des exercices portant sur des durées de quarante-huit heures, d'une semaine et d'un mois permettent de distinguer les fonctions qui tiennent de celles qui s'arrêtent, et d'alimenter la dimension de résilience. Le cas ukrainien rappelle ce que valent des procédures manuelles conservées et entretenues.

7.4 Étendre le périmètre de la continuité d'activité

Les plans de continuité traitent d'ordinaire les pannes internes et les sinistres physiques. Ils doivent intégrer les dépendances numériques externes comme scénarios à part entière, avec un délai de substitution estimé et un plan de repli, plutôt que comme une hypothèse implicite.

7.5 Traiter l'IA et sa chaîne d'approvisionnement comme un domaine de dépendance

Les services d'IA utilisés dans les processus (modèle, nuage, données, interfaces, éditeur) doivent figurer dans la cartographie, avec les mêmes questions que pour toute autre dépendance, auxquelles s'ajoute l'examen des obligations qu'impose le règlement européen sur l'IA aux fournisseurs et aux déployeurs.

7.6 Faire converger les fonctions au niveau de la gouvernance des risques

L'évolution décrite ne signifie pas que le RSSI doive se substituer aux responsables des achats, des opérations, de la continuité ou de l'intelligence économique. Elle suppose une gouvernance transversale, capable de relier des risques techniques, contractuels, industriels et géopolitiques. La grille de la section 3 peut servir de langage commun : cinq questions simples, que chaque fonction sait traiter dans son domaine.

Une illustration fictive montre l'usage de la démarche. Soit un distributeur régional dont la chaîne du froid repose sur un système de supervision unique, hébergé chez un prestataire. La grille donne une dépendance élevée, une concentration élevée, une substitution modérée à élevée (une migration prendrait plusieurs semaines), une propagation élevée (tous les sites) et une résilience faible, faute de procédure manuelle de relevé des températures. La réponse n'est pas nécessairement de changer de prestataire. Elle peut consister à documenter un mode dégradé (relevés manuels, stocks tampons, accord de secours) et à tester une indisponibilité de quarante-huit heures. La décision reste une décision de gouvernance : réduire, diversifier, surveiller ou compenser la dépendance, en connaissance de cause. La résilience ne consiste pas à supprimer toutes les dépendances, mais à identifier celles qui pourraient compromettre les fonctions essentielles.

8. Limites et pistes de recherche

8.1 Limites

Cette étude comporte plusieurs limites. Le corpus est restreint : six situations, choisies pour leur variété et non pour leur représentativité, ne permettent aucune généralisation statistique. Les sources sont documentaires et de qualité inégale. Un rapport annuel d'entreprise ou une estimation d'audit public ne livrent pas des mesures comparables, et plusieurs montants cités sont des estimations datées. Le codage a été réalisé par un seul analyste, sans double codage, et les seuils de la dimension de substitution sont indicatifs. Le cas de l'IA est prospectif : il ne repose pas sur un incident et son codage reste provisoire. Aucune validation auprès de praticiens n'a été menée. La matrice d'intégration de la section 3.6 est une proposition non testée : ses seuils et sa règle de priorisation n'ont été ni calibrés par secteur ni soumis à des praticiens. Enfin, le sujet évolue vite, et certaines sources récentes pourront être précisées ou révisées.

S'y ajoutent les biais déjà évoqués en 4.5 : la documentation abondante des grands incidents, qui peut donner une image plus spectaculaire que la moyenne, et le regard rétrospectif.

8.2 Pistes de recherche

Quatre prolongements paraissent naturels. Le premier est une validation par entretiens semi-directifs auprès de RSSI et de responsables du risque, afin de tester la lisibilité et l'utilité de la grille. Le deuxième est une démarche de type Delphi pour calibrer les seuils de substitution par secteur. Le troisième est un double codage indépendant des cas, qui permettrait d'estimer la fiabilité inter-codeurs. Le quatrième est une application sectorielle (santé, énergie, finance), éventuellement sous la forme d'une étude de cas interne anonymisée, reliant la grille aux registres de prestataires que prévoit DORA ou aux analyses d'impact existantes.

9. Conclusion

Cet article part d'un constat simple : la protection du système d'information ne suffit plus à décrire ce dont une organisation dépend pour fonctionner. Il propose de distinguer un périmètre technique de sécurité et un périmètre de dépendance, de classer les dépendances en cinq catégories et de les examiner par cinq questions : dépendance, concentration, substitution, propagation, résilience. Appliquée à six situations, cette grille permet de rapprocher des événements très différents, d'une opération étatique contre une chaîne logicielle à une restriction d'exportation de matériaux.

Les cas suggèrent que la criticité d'une dépendance tient d'abord à la concentration de l'offre, à la difficulté de la remplacer et à l'absence de mode dégradé. Le rôle de la géopolitique y est réel mais indirect : elle modifie la probabilité et la durée d'une perturbation sans en constituer la cause unique. Cette conclusion est une hypothèse de travail étayée par des cas, non un résultat démontré, et elle appelle les validations décrites en 8.2.

Pour les fonctions de gouvernance, de risque et de conformité, la conséquence est pratique. Il s'agit de cartographier ce dont l'activité dépend réellement, de tester ce qui se passe quand une ressource manque, et de décider en connaissance de cause quelles dépendances réduire, diversifier, surveiller ou compenser. La cyber-résilience ne consiste pas seulement à empêcher la crise d'entrer dans l'organisation. Elle suppose aussi de pouvoir continuer à fonctionner lorsque la crise est déjà là.

Références

A. P. Moller-Maersk. (2018). *Annual Report 2017*. https://www.maersk.com/

Buchanan, B. (2017). *The cybersecurity dilemma: Hacking, trust and fear between nations*. Oxford University Press.

CERT-FR. (2020, mise à jour 2021). *Présence de code malveillant dans SolarWinds Orion* (Alerte CERTFR-2020-ALE-026). https://www.cert.ssi.gouv.fr/

Christopher, M., & Peck, H. (2004). Building the resilient supply chain. *The International Journal of Logistics Management, 15*(2), 1-14.

CISA. (2016). *Cyber-attack against Ukrainian critical infrastructure* (Alerte IR-ALERT-H-16-056-01). https://www.cisa.gov/

CISA. (2020, 13 décembre). *Emergency Directive 21-01: Mitigate SolarWinds Orion code compromise*. https://www.cisa.gov/

Commission européenne / Groupe de coopération SRI. (2026, 13 février). *Boîte à outils pour améliorer la sécurité de la chaîne d'approvisionnement des TIC* [EU ICT Supply Chain Security Toolbox]. https://digital-strategy.ec.europa.eu/fr/library/toolbox-improve-ict-supply-chain-security

Conseil de l'Union européenne. (2026, 16 mars). *Council adopts conclusions on advancing the EU's capacity to counter hybrid threats* (Communiqué de presse 192/26). https://www.consilium.europa.eu/

Directive (UE) 2022/2555 du Parlement européen et du Conseil du 14 décembre 2022 concernant des mesures destinées à assurer un niveau élevé commun de cybersécurité dans l'ensemble de l'Union (directive NIS 2). *Journal officiel de l'Union européenne*, L 333, 27 décembre 2022.

Eisenhardt, K. M. (1989). Building theories from case study research. *Academy of Management Review, 14*(4), 532-550.

ENISA. (2025, 1er octobre). *ENISA Threat Landscape 2025*. European Union Agency for Cybersecurity.

ENISA. (2026a, 22 septembre). *ENISA Threat Landscape 2026*. European Union Agency for Cybersecurity.

ENISA. (2026b, 22 septembre). *Exploring the evolution of the cyber threat landscape: How dependencies weaken our digital resilience* [Communiqué de presse].

Farrell, H., & Newman, A. L. (2019). Weaponized interdependence: How global economic networks shape state coercion. *International Security, 44*(1), 42-79.

Flyvbjerg, B. (2006). Five misunderstandings about case-study research. *Qualitative Inquiry, 12*(2), 219-245.

Greenberg, A. (2018, 22 août). The untold story of NotPetya, the most devastating cyberattack in history. *Wired*.

Help Net Security. (2017, 17 août). *NotPetya aftermath: Companies lost hundreds of millions*. https://www.helpnetsecurity.com/2017/08/17/notpetya-losses/

Hollnagel, E., Woods, D. D., & Leveson, N. (Eds.). (2006). *Resilience engineering: Concepts and precepts*. Ashgate.

International Energy Agency. (2025). *With new export controls on critical minerals, supply concentration risks become reality*. https://www.iea.org/

ISO. (2019). *ISO 22301:2019 Sécurité et résilience : systèmes de management de la continuité d'activité*.

ISO/IEC. (2022). *ISO/IEC 27001:2022 Sécurité de l'information, cybersécurité et protection de la vie privée*.

ISO/IEC. (2021). *ISO/IEC 27036-1:2021 Sécurité de l'information dans les relations avec les fournisseurs*.

Jaakkola, E. (2020). Designing conceptual articles: Four approaches. *AMS Review, 10*, 18-26.

Keohane, R. O., & Nye, J. S. (1977). *Power and interdependence: World politics in transition*. Little, Brown.

Lee, R. M., Assante, M. J., & Conway, T. (2016). *Analysis of the cyber attack on the Ukrainian power grid: Defense use case*. SANS ICS / E-ISAC.

Miller & Chevalier. (2026, 12 août). *BIS export controls 2025 year-in-review and 2026 mid-year update*. https://www.millerchevalier.com/publication/bis-export-controls-2025-year-review-and-2026-mid-year-update

Perrow, C. (1984). *Normal accidents: Living with high-risk technologies*. Basic Books.

Règlement (UE) 2022/2554 (DORA). *Journal officiel de l'Union européenne*, L 333, 27 décembre 2022.

Règlement (UE) 2024/1689 (règlement sur l'IA). *Journal officiel de l'Union européenne*, L, 12 juillet 2024.

Règlement (UE) 2024/2847 (règlement sur la cyber-résilience). *Journal officiel de l'Union européenne*, L, 20 novembre 2024.

Rid, T. (2012). Cyber war will not take place. *Journal of Strategic Studies, 35*(1), 5-32.

Ross, R., et al. (2021). *Developing cyber-resilient systems* (NIST SP 800-160 Vol. 2 Rev. 1). NIST.

Sheffi, Y. (2005). *The resilient enterprise: Overcoming vulnerability for competitive advantage*. MIT Press.

SolarWinds Corporation. (2020, 14 décembre). *Form 8-K*. U.S. Securities and Exchange Commission. https://www.sec.gov/Archives/edgar/data/1739942/000162828020017451/swi-20201214.htm

The White House. (2018, 15 février). Statement from the Press Secretary.

The White House. (2021, 15 avril). Fact sheet: Imposing costs for harmful foreign activities by the Russian government.

U.S. Department of Commerce / BIS. (2025). Framework for Artificial Intelligence Diffusion. *Federal Register, 90* FR 4544.

U.S. Department of Justice. (2020, 19 octobre). Six Russian GRU officers charged… [Communiqué de presse].

U.S. Government Accountability Office. (2024). *Healthcare cybersecurity: HHS continues to have challenges as lead agency* (GAO-25-107755).

UnitedHealth Group. (2025). *Form 10-K for the fiscal year ended December 31, 2024*. U.S. Securities and Exchange Commission. https://www.sec.gov/Archives/edgar/data/731766/000073176625000063/unh-20241231.htm

Vassilev, A., Oprea, A., Fordyce, A., Anderson, H., Davies, X., & Hamin, M. (2025). *Adversarial machine learning: A taxonomy and terminology of attacks and mitigations* (NIST AI 100-2 E2025). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.AI.100-2e2025

Yin, R. K. (2018). *Case study research and applications: Design and methods* (6e éd.). Sage.

Annexes et déclarations

Annexe A. Règles de codage du niveau de preuve géopolitique

Niveau	Définition	Règle d'attribution	Cas concernés
A	Attribution étatique officielle ou inculpation documentée	Au moins une autorité publique a formellement imputé l'opération à un acteur étatique ou à ses agents	NotPetya, SolarWinds, réseau ukrainien
B	Contexte géopolitique documenté, sans attribution formelle partagée	Des rapports institutionnels établissent le contexte, mais aucune imputation formelle n'existe	Aucun dans le corpus
C	Impact systémique sans lien géopolitique établi	Incident documenté, aucun élément ne le relie à une stratégie d'État	Change Healthcare
D	Perturbation résultant d'une décision publique non cyber	Mesure réglementaire, commerciale ou de contrôle des exportations	Terres rares, IA (couche de calcul)

En cas de doute entre deux niveaux, on retient celui qui suppose le moins de lien géopolitique.

Annexe B. Sources principales par cas

Cas	Sources principales
NotPetya et Maersk	A. P. Moller-Maersk (2018) ; The White House (2018) ; U.S. Department of Justice (2020) ; Greenberg (2018) ; Help Net Security (2017)
SolarWinds	CERT-FR (2020) ; CISA (2020) ; SolarWinds Corporation (2020) ; The White House (2021)
Réseau électrique ukrainien	CISA (2016) ; Lee et al. (2016) ; U.S. Department of Justice (2020)
Change Healthcare	U.S. GAO (2024) ; UnitedHealth Group (2025)
Terres rares	IEA (2025)
IA et calcul	ENISA (2025, 2026b) ; Vassilev et al. (2025) ; U.S. Department of Commerce / BIS (2025) ; Miller & Chevalier (2026)

Annexe C. Glossaire

- **GRC** : gouvernance, risque et conformité.
- **OT** : technologies opérationnelles (systèmes de contrôle industriels et équipements techniques connectés).
- **RSSI** : responsable de la sécurité des systèmes d'information.
- **SI** : système d'information.
- **SRI / NIS** : sécurité des réseaux et des systèmes d'information.
- **TIC** : technologies de l'information et de la communication.

Annexe D. Justification du codage

Les jugements relatifs à la substitution et à la résilience sont ceux de l'auteur ; ils devront être soumis à un second codeur (voir 8.2).

Cas	Justification par dimension
NotPetya / Maersk	Dépendance élevée : canal de mise à jour d'un logiciel comptable et parc informatique interconnecté. Concentration modérée : logiciel répandu surtout en Ukraine. Substitution modérée : reconstruction du parc en quelques jours à quelques semaines. Propagation élevée : perturbation des opérations portuaires et logistiques. Résilience faible : reprise liée à une copie préservée par hasard (Greenberg, 2018).
SolarWinds	Dépendance et concentration élevées : plateforme de supervision installée chez des milliers de clients, dotée de privilèges étendus. Substitution élevée : remplacer un outil de supervision est un chantier de plusieurs mois (jugement de l'auteur). Propagation élevée : clients répartis dans de nombreux secteurs. Résilience faible : détection tardive.
Réseau ukrainien	Dépendance élevée : commande à distance des postes de distribution. Concentration modérée : trois distributeurs aux architectures proches. Substitution modérée : courant rétabli en quelques heures, systèmes de contrôle remis en état plus lentement. Propagation modérée : environ 225 000 clients. Résilience partielle : procédures manuelles conservées.
Change Healthcare	Dépendance, concentration et propagation élevées : intermédiaire central du traitement des paiements et des opérations administratives de santé. Substitution classée élevée (migration de flux, de contrats et d'intégrations) ; ce codage est à discuter, certains prestataires ayant pu recourir à d'autres intermédiaires en des délais plus courts. Résilience faible : répercussions étendues sur les prestataires de soins (U.S. GAO, 2024).
Terres rares	Dépendance, concentration et propagation élevées : parts de la Chine dans la chaîne des terres rares et des aimants (IEA, 2025). Substitution élevée : développer des capacités de raffinage et de fabrication hors de Chine demande des années (jugement de l'auteur). Résilience partielle : certains constructeurs ont réduit leur production sans l'arrêter.
IA et calcul	Codage indicatif, sans incident documenté : concentration et substitution élevées (calcul, modèles, nuage), dépendance modérée à élevée selon les organisations, propagation modérée, résilience à documenter.

Déclarations

- **Conflits d'intérêts :** aucun.
- **Financement :** fonds propres de l'auteur (marque Twagirumukiza).
- **Disponibilité des données :** les données proviennent de sources publiques citées dans les références. Le codage des cas figure en 6.1 et à l'annexe A.
- **Usage d'outils d'intelligence artificielle générative :** usage de l'IA pour la correction.